제안용 샘플 · 예시 형식 — 실제 코드를 받기 전에 만든 견본이에요. 판정, 발견 사항, 파일 위치, 숫자는 모두 가상이에요. 버전 지원 날짜처럼 출처를 적은 것만 실제로 확인한 사실이에요.

1주차 인수·검수 보고서

현장 서비스 관리 웹, 이대로 넘겨받아도 될까요

대상 공간향기 B2B 현장 서비스 관리 웹 기술 React 18 · NestJS 10 · Prisma 6 · PostgreSQL 17 검토 기간 착수 1주차 (월~금)

범위 화면 46개 · API 전체 · 테이블 73개 · 자체 시험 143건 작성 제이에스 오퍼레이션

판정 (예시)

보완하면 그대로 넘겨받을 수 있어요

다시 짤 필요는 없어 보여요. 문제는 설정과 일부 파일에 몰려 있어요. 다만 키 관리와 로그인 토큰은 서버에 올리기 전에 꼭 고쳐야 해요.

그대로 인수	**보완 후 인수 · 지금 판정**	일부 다시 짜기	전면 다시 짜기
치명·높음 0건, 설명서대로 새 서버에 바로 설치됨	제안 범위 안에서 고칠 수 있는 문제만 있음	한 기능은 고치기보다 새로 짜는 게 빠름, 따로 협의	DB 설계가 업무 흐름과 맞지 않음

오픈 전에 꼭 고칠 것

6일

8건 · 제안서 ②③ 범위 안이에요

치명	2건
높음	5건
중간	5건
낮음	2건

이렇게 확인했어요

받은 설명서만 보고 새 서버에 처음부터 설치해 보는 데서 시작해요. 개발 PC에서 되는 것과 서버에서 되는 것은 달라서요.

1주차 5일

월	**처음부터 설치해 보기**	인계서만 보고 새 서버에 설치·빌드하고, 빈 DB에 구조를 만들어요.
화	**자동 검사**	시험 143건 다시 실행, 의존성 취약점, 키 노출, 보안 규칙 검사.
수	**직접 읽기**	로그인·토큰·암호화 코드를 읽고, 5개 팀 권한표와 API를 맞춰 봐요.
목	**데이터 넣어 보기**	가짜 데이터 1만 건으로 화면별 쿼리 수와 응답 시간을 재요.
금	**보고서와 설명**	이 보고서를 드리고 영등포에서 1시간 설명, 2주차 계획을 정해요.

통과했다던 시험, 다시 돌려 봤어요

시험	받은 결과	다시 돌린 결과
백엔드 시나리오	83 통과	79 통과 · 4 실패
API 연결	60 통과	60 통과
화면 시험	통과	패드 1대 확인

백엔드 시험 83건 중 52건이 실제 DB 대신 가짜(mock)를 쓰고 있었어요. 실제 DB로 바꿔 돌리니 4건이 실패했어요. AI가 시험을 통과시키려고 가짜를 넣는 일이 흔해서 꼭 봐요. (예시)

AI가 쓴 NestJS·Prisma 코드에서 꼭 보는 8가지

저도 AI 개발 도구로 일해서, AI가 어디서 자주 빠뜨리는지 알아요. 화면에서 잘 돌아가도 아래 8가지는 따로 확인해요.

영역	무엇을 보나	AI 코드에서 잘 생기는 이유	확인 방법	결과 (예시)
보안 기본 로그인·권한·입력 검사	• 모든 API에 로그인 확인이 걸려 있는지 • 5개 팀 권한표대로 막히는지 • 모르는 칸(예: role)을 몰래 보내도 버리는지 • 로그인 시도 횟수 제한	화면에 버튼이 없는 API는 막는 걸 자주 빠뜨려요. 화면 시험으로는 드러나지 않아요.	팀별 시험 계정으로 API를 하나씩 직접 호출	높음 2
환경변수·키 암호화 키, 비밀번호	• 코드와 저장소 기록(git)에 키가 남았는지 • 키가 없을 때 기본값으로 켜지지 않는지 • 같은 값이 늘 같은 암호문이 되지 않는지 • 키를 바꾸는 방법이 있는지	오류를 물어보며 .env를 통째로 붙여 넣는 일이 많아, 개발용 키가 여기저기 남아요.	저장소 전체 기록 키 검사, 암호화 함수 직접 읽기	치명 1
로그인 토큰 JWT 방식	• 토큰 유효 시간과 저장 위치 • 로그아웃·퇴사 때 바로 막히는지 • 비밀번호를 바꾸면 다른 기기가 끊기는지	예제처럼 '오래 가는 토큰 하나'로 끝내는 경우가 많아요.	토큰을 꺼내 만료·폐기 동작을 직접 시험	치명 1 높음 1
CORS·배포 설정 운영 모드	• 모든 주소 허용 + 쿠키 허용인지 • 개발 서버(vite dev, start:dev)로 돌고 있지 않은지 • API 문서 화면이 운영에 열려 있지 않은지 • 보안 헤더	패드에서 같은 와이파이로 접속 시험을 하려고 '모두 허용'으로 풀어 둔 채 남기 쉬워요.	설정 파일 확인, 다른 주소에서 요청 보내 보기	높음 1
N+1 쿼리 느려지는 목록	• 반복문 안에서 DB를 한 건씩 부르는지 • 목록에 페이지 나누기가 있는지 • 관계 칸 인덱스 • 필요 없는 칸까지 다 가져오는지	데이터가 몇 건뿐인 개발 PC에서는 느린 게 보이지 않아요. 실제 데이터가 들어가야 드러나요.	쿼리 기록을 켜고 화면마다 쿼리 수 세기	중간 2
마이그레이션 DB 구조 변경 기록	• 기록과 실제 DB 구조가 같은지 • 빈 DB에서 한 번에 만들어지는지 • db push·reset으로 맞춰 오지 않았는지 • 시드에 고정 관리자 비밀번호가 없는지	스키마 오류가 나면 DB를 지우고 다시 맞추는 방법을 자주 써요. 운영에서는 데이터가 지워져요.	빈 DB에 migrate deploy, 구조 차이 비교	중간 1
에러 처리·기록 오류 응답, 로그	• DB 오류를 알맞은 문구로 바꾸는지 • 응답에 SQL·내부 경로가 보이지 않는지 • 로그에 전화번호·주소가 찍히지 않는지 • 개인정보 접속기록	파일마다 오류 처리 방식이 다르고, 디버깅하려고 요청 내용을 통째로 찍어 둔 줄이 남아요.	일부러 틀린 값 보내기, 로그 파일 검색	중간 2
의존성 취약점 Node·라이브러리 버전	• 알려진 취약점 (npm audit) • 지원이 끝난 버전 • 없는 패키지나 이름이 비슷한 가짜 패키지 • lock 파일로 같은 버전이 설치되는지	AI는 배운 시점의 버전을 써서 처음부터 오래된 버전일 때가 있어요. 없는 패키지 이름을 지어내기도 해요.	npm audit, 패키지 실제 존재·다운로드 수 확인	높음 1 낮음 1

발견 사항 14건

모두 예시예요. 실제 보고서에는 파일·행 위치, 다시 일으키는 방법, 고친 뒤 확인한 결과가 함께 들어가요.

● 치명	● 높음	● 중간	● 낮음
지금 바로 정보가 새거나, 남이 관리자처럼 쓸 수 있어요.	조건이 맞으면 정보가 새거나 서비스가 멈춰요.	데이터가 쌓이면 느려지거나, 운영·법 기준에 못 미쳐요.	당장 문제는 없지만 나중에 고치는 비용을 올려요.
발견한 날 바로 알리고, 오픈 전 반드시	오픈 전 반드시	오픈 전 권장, 늦어도 오픈 후 1개월	안정화 기간

번호·영역	내용	심각도	고치는 방법	공수	언제
K-01 키 관리	**개인정보 암호화 키가 저장소 기록에 남아 있어요** 지금 파일에서는 지웠지만 예전 커밋에 그대로 있어요. 소스를 받은 사람은 누구나 주소·전화번호를 풀 수 있어요. `.env · 커밋 a3f9c1e`	● 치명	운영용 키를 새로 만들고 기록에서 지워요. 실제 데이터가 아직 없어서 지금 바꾸면 다시 암호화할 것도 없어요. 키 사본은 대표님이 따로 보관해요.	0.5 일	오픈 전 필수
T-01 로그인 토큰	**토큰 서명 키에 기본값 'secret'이 들어 있어요** 서버 설정에서 키가 빠지면 'secret'으로 켜져요. 이 값을 아는 사람은 관리자 토큰을 직접 만들 수 있어요. `src/auth/jwt.strategy.ts:14`	● 치명	키가 없으면 서버가 아예 켜지지 않게 바꾸고, 길고 무작위인 키를 써요.	0.5 일	오픈 전 필수
T-02 로그인 토큰	**로그인 토큰이 7일 동안 살아 있고, 로그아웃해도 막히지 않아요** 토큰을 브라우저 저장소에 둬요. 패드를 잃어버리거나 직원이 퇴사해도 7일 동안 접속돼요. `src/auth/auth.service.ts`	● 높음	15분짜리 접속 토큰과 쿠키(httpOnly)에 담은 갱신 토큰으로 바꿔요. 계정을 끄면 바로 막혀요.	2 일	오픈 전 필수
A-01 권한	**직원 목록 API가 모든 직원의 전화·이메일을 돌려줘요** 로그인만 하면 팀과 관계없이 18명 전체 연락처가 내려와요. 화면에는 이름만 보여서 시험에서 드러나지 않았어요. `GET /api/users`	● 높음	팀별 권한을 확인하고, 화면에 필요한 칸만 내보내요. 같은 방식으로 API 전체를 권한표와 맞춰 봐요.	0.5 일	오픈 전 필수
C-01 CORS	**어느 사이트에서든 로그인 상태로 API를 부를 수 있어요** 패드 접속 시험 때 '모든 주소 허용'으로 풀어 둔 설정이 그대로 있어요. `src/main.ts · enableCors({ origin: true, credentials: true })`	● 높음	화면과 API를 같은 주소로 내보내 CORS가 필요 없게 해요. 꼭 필요하면 회사 주소 하나만 허용해요.	0.5 일	오픈 전 필수
S-01 보안 기본	**로그인 시도 횟수 제한이 없어요** 비밀번호를 계속 바꿔 넣어 볼 수 있어요. `src/auth/auth.controller.ts`	● 높음	1분에 5번까지만 받고, 계속 틀리면 잠시 잠가요.	0.5 일	오픈 전 필수

D-01 의존성	**Node 20을 쓰고 있어요 (2026년 4월 30일 지원 종료)** 더 이상 보안 패치가 나오지 않아요. 종료 날짜는 Node.js 공식 일정에서 확인한 사실이에요. `package.json · .nvmrc`	높음	Node 24 LTS(2028년 4월까지 지원)로 올리고 자체 시험 143건을 다시 돌려요.	1 일	오픈 전 필수
M-01 마이그레이션	**마이그레이션 기록 없이 db push로 DB를 맞춰 왔어요** 서버 DB를 같은 구조로 만들 정확한 순서가 없어요. 나중에 칸을 바꾸면 운영 데이터가 지워질 수 있어요. `prisma/migrations 폴더 없음`	중간	지금 구조를 기준점으로 기록하고, 서버에는 migrate deploy만 쓰도록 자동 배포에 넣어요.	0.5 일	오픈 전 필수
Q-01 N+1 쿼리	**방문일지 목록 50건에 쿼리가 101번 나가요** 반복문 안에서 고객사와 담당자를 한 건씩 다시 불러와요. 지금은 빠르지만 1년치가 쌓이면 느려져요. `src/visit-log/visit-log.service.ts:62`	중간	관계 데이터를 한 번에 가져오고, 목록에 페이지 나누기를 넣어요.	0.5 일	오픈 전 권장
Q-02 인덱스	**관계 칸 21곳에 인덱스가 없어요** PostgreSQL은 외래키 칸에 인덱스를 자동으로 만들지 않아요. 가짜 데이터 1만 건에서 고객사별 이슈 조회가 1.8초 걸렸어요. `prisma/schema.prisma`	중간	자주 찾는 칸에 인덱스를 더하고 다시 재요.	0.5 일	오픈 전 권장
E-01 에러 처리	**DB 오류가 그대로 '서버 오류'로 나가고, 응답에 테이블 이름이 보여요** 같은 장비 번호를 두 번 넣으면 이유 없이 실패하고, 개발자 도구에서 내부 정보가 보여요. `전역 예외 필터 없음`	중간	Prisma 오류 코드를 안내 문구로 바꾸는 필터를 하나 두고, 운영에서는 내부 정보를 숨겨요.	0.5 일	오픈 전 권장
L-01 접속기록	**누가 어떤 고객의 개인정보를 봤는지 기록이 없어요** 개인정보 안전성 확보조치 기준 제8조는 접속기록을 1년 이상 보관하라고 해요. 이 시스템에 어떻게 적용되는지는 확인이 필요해요.	중간	고객 연락처 조회와 내려받기를 기록하는 테이블을 두고 1년 보관해요.	1 일	오픈 전 권장
D-02 의존성	**prisma@latest로 설치하면 8.0 정식 전 버전이 깔려요** 10월 21일 npm에서 latest 표시가 8.0.0-rc.24를 가리키는 걸 실제로 확인했어요. 설치할 때마다 버전이 달라질 수 있어요. `README 설치 안내`	낮음	버전을 정확히 고정하고, 서버에서는 lock 파일 그대로 설치해요(npm ci).	0.5 일	오픈 전 권장
A-02 AI 코드 정리	**같은 날짜 변환 함수가 7곳에 따로 있어요** 조금씩 달라서 한 곳만 고치면 화면마다 날짜가 달라질 수 있어요. 쓰이지 않는 파일도 38개 있어요. `web/src/utils/ 외 6곳`	낮음	하나로 모으고 한국 시간 기준 시험을 더해요. 안 쓰는 파일은 지워요.	1 일	안정화 기간

고치는 순서와 공수

반나절 단위로 적어요. 제안서의 ② 서버 구축(6일)과 ③ 보안 보완(8일) 안에 들어가고, 넘치면 먼저 여쭤보고 정해요.

언제 고치나

오픈 전 필수 · 8건 — **6** 일

치명·높음 전부와 마이그레이션 기준점

오픈 전 권장 · 5건 — **3** 일

느려짐 대비, 오류 문구, 접속기록, 버전 고정

안정화 기간 · 1건 — **1** 일

중복 코드 정리 (오픈 후 3개월 안에)

합계 14건 · 10일 (예시)

오픈 전 필수 8건은 이 순서로 고쳐요

1. **키부터 바꿔요**
   K-01, T-01 · 다른 수정이 새 키 위에서 이뤄지게
2. **문을 닫아요**
   A-01, C-01, S-01 · 권한, CORS, 로그인 시도 제한
3. **토큰 방식을 바꿔요**
   T-02 · 가장 큰 작업이라 따로 시험 기간을 둬요
4. **버전을 올려요**
   D-01 · Node 24 LTS, 올린 뒤 시험 143건 다시 실행
5. **배포 순서를 고정해요**
   M-01 · 서버에는 기록된 마이그레이션만 적용

결정해 주실 것

2주차 서버 구축 전에 정하면 좋은 것들이에요.

회사 메일이 Google Workspace인가요?

구글 캘린더 연동 앱을 '테스트' 상태로 두면 연결이 7일마다 끊겨요(구글 공식 문서). Workspace라면 '내부 앱'으로 설정해 구글 검수 없이 쓸 수 있어요.

현장 패드를 여러 직원이 같이 쓰나요?

같이 쓰면 자동 로그아웃 시간을 짧게 정해야 해요.

메일은 어느 계정으로 보낼까요?

회사 메일 계정으로 보낼지, 발송 서비스를 쓸지 정해요. 스팸함에 안 들어가게 도메인 설정(SPF·DKIM)도 함께 해요.

도메인

회사 도메인이 있으면 하위 주소(예: field.회사도메인)로 추가 비용 없이 써요.

기존 자료

파일 형식과 대략의 건수를 알려 주시면 이관 리허설을 미리 해 봐요.